

Governance Review Card

Section	Issue/ Definition	Impact	Suggested fix/ Mitigation
1. Confidentiality Risk	HTTP is used for client traffic and the databases/admin path is exposed or insufficiently isolated. This violates the CIA Triad's Confidentiality principle.	PII such as names, emails and phone numbers could be intercepted or disclosed; database exposure could cause a large-scale privacy breach.	Enforce HTTPS/TLS end-to-end, redirect HTTP to HTTPS, place databases in private subnets, restrict security-group access, encrypt sensitive data at rest, and use a secrets manager.
2. Integrity Risk	The application uses SQL queries without prepared statements and has weak input validation. This conflicts with Input Validation and Secure SDLC principles.	An attacker could inject SQL, modify/delete records, bypass application logic, or corrupt user/event data.	Use parameterized queries/ORM, strict server-side validation, output encoding, allow-lists where appropriate, and automated security tests in CI/CD.
3. Availability Risk	Public-facing infrastructure has no visible rate limiting, monitoring, or incident-response capability, increasing the risk of resource exhaustion and prolonged outages. This concerns the Availability leg of the CIA Triad.	Abuse or an attack could exhaust web/API/database resources, interrupt messaging or registration, and reduce trust during events.	Add API/WAF rate limiting, autoscaling/health checks, database backups and tested restoration, centralized monitoring, alerting, and an incident-response runbook.

Monitoring / Reporting Recommendation

Metric to Monitor	Definition	Visualization Type	Why It Matters
Failed authentication / authorization rate	Number of failed login, token-validation, and authorization requests per minute, segmented by endpoint and source.	Line chart with threshold/alert markers	A sudden increase can reveal credential attacks, privilege-abuse attempts, or misconfigured clients early enough for investigation and response.